

discretionary access control	An access control policy that is enforced over all subjects and objects in a system where the policy specifies that a subject that has been granted access to information can do one or more of the following: pass the information to other subjects or objects; grant its privileges to other subjects; change the security attributes of subjects, objects, systems, or system components; choose the security attributes to be associated with newly-created or revised objects; or change the rules governing access control. Mandatory access controls restrict this capability.
disassociability [IR 8062]	Enabling the processing of personally identifiable information or events without association to individuals or devices beyond the operational requirements of the system.
domain	An environment or context that includes a set of system resources and a set of system entities that have the right to access the resources as defined by a common security policy, security model, or security architecture. See <i>security domain</i> .
enterprise [CNSSI 4009]	An organization with a defined mission/goal and a defined boundary, using systems to execute that mission, and with responsibility for managing its own risks and performance. An enterprise may consist of all or some of the following business aspects: acquisition, program management, human resources, financial management, security, and systems, information and mission management. See <i>organization</i> .
enterprise architecture [OMB A-130]	A strategic information asset base, which defines the mission; the information necessary to perform the mission; the technologies necessary to perform the mission; and the transitional processes for implementing new technologies in response to changing mission needs; and includes a baseline architecture; a target architecture; and a sequencing plan.
environment of operation [OMB A-130]	The physical surroundings in which an information system processes, stores, and transmits information.
event [SP 800-61, Adapted]	Any observable occurrence in a system.
executive agency [OMB A-130]	An executive department specified in 5 U.S.C., Sec. 101; a military department specified in 5 U.S.C., Sec. 102; an independent establishment as defined in 5 U.S.C., Sec. 104(1); and a wholly owned Government corporation fully subject to the provisions of 31 U.S.C., Chapter 91.
exfiltration	The unauthorized transfer of information from a system.
external system (or component)	A system or component of a system that is used by but is not a part of an organizational system and for which the organization has no direct control over the implementation of required security and privacy controls or the assessment of control effectiveness.

external system service	A system service that is provided by an external service provider and for which the organization has no direct control over the implementation of required security and privacy controls or the assessment of control effectiveness.
external system service provider	A provider of external system services to an organization through a variety of consumer-producer relationships, including joint ventures, business partnerships, outsourcing arrangements (i.e., through contracts, interagency agreements, lines of business arrangements), licensing agreements, and/or supply chain exchanges.
external network	A network not controlled by the organization.
failover	The capability to switch over automatically (typically without human intervention or warning) to a redundant or standby system upon the failure or abnormal termination of the previously active system.
federal information system [OMB A-130]	An information system used or operated by an executive agency, by a contractor of an executive agency, or by another organization on behalf of an executive agency.
FIPS-validated cryptography	A cryptographic module validated by the Cryptographic Module Validation Program (CMVP) to meet requirements specified in FIPS Publication 140-3 (as amended). As a prerequisite to CMVP validation, the cryptographic module is required to employ a cryptographic algorithm implementation that has successfully passed validation testing by the Cryptographic Algorithm Validation Program (CAVP). See <i>NSA-approved cryptography</i> .
firmware [CNSSI 4009]	Computer programs and data stored in hardware - typically in read-only memory (ROM) or programmable read-only memory (PROM) - such that the programs and data cannot be dynamically written or modified during execution of the programs. See <i>hardware</i> and <i>software</i> .
hardware [CNSSI 4009]	The material physical components of a system. See <i>software</i> and <i>firmware</i> .
high-impact system [FIPS 200]	A system in which at least one security objective (i.e., confidentiality, integrity, or availability) is assigned a FIPS Publication 199 potential impact value of high.
hybrid control [OMB A-130]	A security or privacy control that is implemented for an information system in part as a common control and in part as a system-specific control.
identifier [FIPS 201-2]	Unique data used to represent a person's identity and associated attributes. A name or a card number are examples of identifiers. A unique label used by a system to indicate a specific entity, object, or group.

impact	The effect on organizational operations, organizational assets, individuals, other organizations, or the Nation (including the national security interests of the United States) of a loss of confidentiality, integrity, or availability of information or a system.
impact value [FIPS 199]	The assessed worst-case potential impact that could result from a compromise of the confidentiality, integrity, or availability of information expressed as a value of low, moderate or high.
incident [FISMA]	An occurrence that actually or imminently jeopardizes, without lawful authority, the confidentiality, integrity, or availability of information or an information system; or constitutes a violation or imminent threat of violation of law, security policies, security procedures, or acceptable use policies.
industrial control system [SP 800-82]	General term that encompasses several types of control systems, including supervisory control and data acquisition (SCADA) systems, distributed control systems (DCS), and other control system configurations such as programmable logic controllers (PLC) found in the industrial sectors and critical infrastructures. An industrial control system consists of combinations of control components (e.g., electrical, mechanical, hydraulic, pneumatic) that act together to achieve an industrial objective (e.g., manufacturing, transportation of matter or energy).
information [OMB A-130]	Any communication or representation of knowledge such as facts, data, or opinions in any medium or form, including textual, numerical, graphic, cartographic, narrative, electronic, or audiovisual forms.
information flow control	Controls to ensure that information transfers within a system or organization are not made in violation of the security policy.
information leakage	The intentional or unintentional release of information to an untrusted environment.
information owner [SP 800-37]	Official with statutory or operational authority for specified information and responsibility for establishing the controls for its generation, collection, processing, dissemination, and disposal.
information resources [OMB A-130]	Information and related resources, such as personnel, equipment, funds, and information technology.
information security [OMB A-130]	The protection of information and systems from unauthorized access, use, disclosure, disruption, modification, or destruction in order to provide confidentiality, integrity, and availability.
information security architecture [OMB A-130]	An embedded, integral part of the enterprise architecture that describes the structure and behavior of the enterprise security processes, security systems, personnel and organizational subunits, showing their alignment with the enterprise's mission and strategic plans.

information security policy [CNSSI 4009]	Aggregate of directives, regulations, rules, and practices that prescribes how an organization manages, protects, and distributes information.
information security program plan [OMB A-130]	Formal document that provides an overview of the security requirements for an organization-wide information security program and describes the program management controls and common controls in place or planned for meeting those requirements.
information security risk [SP 800-30]	The risk to organizational operations (including mission, functions, image, reputation), organizational assets, individuals, other organizations, and the Nation due to the potential for unauthorized access, use, disclosure, disruption, modification, or destruction of information and/or systems.
information steward [SP 800-37]	An agency official with statutory or operational authority for specified information and responsibility for establishing the controls for its generation, collection, processing, dissemination, and disposal.
information system [USC 3502]	A discrete set of information resources organized for the collection, processing, maintenance, use, sharing, dissemination, or disposition of information.
information technology [USC 11101]	Any services, equipment, or interconnected system(s) or subsystem(s) of equipment, that are used in the automatic acquisition, storage, analysis, evaluation, manipulation, management, movement, control, display, switching, interchange, transmission, or reception of data or information by the agency. For purposes of this definition, such services or equipment if used by the agency directly or is used by a contractor under a contract with the agency that requires its use; or to a significant extent, its use in the performance of a service or the furnishing of a product. Information technology includes computers, ancillary equipment (including imaging peripherals, input, output, and storage devices necessary for security and surveillance), peripheral equipment designed to be controlled by the central processing unit of a computer, software, firmware and similar procedures, services (including cloud computing and help-desk services or other professional services which support any point of the life cycle of the equipment or service), and related resources. Information technology does not include any equipment that is acquired by a contractor incidental to a contract which does not require its use.
information technology product	See <i>system component</i> .

information type [FIPS 199]	A specific category of information (e.g., privacy, medical, proprietary, financial, investigative, contractor-sensitive, security management) defined by an organization or in some instances, by a specific law, Executive Order, directive, policy, or regulation.
insider [CNSSI 4009, Adapted]	Any person with authorized access to any organizational resource, to include personnel, facilities, information, equipment, networks, or systems.
insider threat [CNSSI 4009, Adapted]	The threat that an insider will use her/his authorized access, wittingly or unwittingly, to do harm to the security of organizational operations and assets, individuals, other organizations, and the Nation. This threat can include damage through espionage, terrorism, unauthorized disclosure of national security information, or through the loss or degradation of organizational resources or capabilities.
insider threat program [CNSSI 4009, Adapted]	A coordinated collection of capabilities authorized by the organization and used to deter, detect, and mitigate the unauthorized disclosure of information.
interface [CNSSI 4009]	Common boundary between independent systems or modules where interactions take place.
integrity [FISMA]	Guarding against improper information modification or destruction, and includes ensuring information non-repudiation and authenticity.
internal network	A network where the establishment, maintenance, and provisioning of security controls are under the direct control of organizational employees or contractors. Cryptographic encapsulation or similar security technology implemented between organization-controlled endpoints provides the same effect (at least regarding confidentiality and integrity). An internal network is typically organization-owned yet may be organization-controlled while not being organization-owned.
label	See <i>security label</i> .
least privilege [CNSSI 4009]	The principle that a security architecture is designed so that each entity is granted the minimum system resources and authorizations that the entity needs to perform its function.
local access	Access to an organizational system by a user (or process acting on behalf of a user) communicating through a direct connection without the use of a network.

logical access control system	An automated system that controls an individual's ability to access one or more computer system resources, such as a workstation, network, application, or database. A logical access control system requires the validation of an individual's identity through some mechanism, such as a PIN, card, biometric, or other token. It has the capability to assign different access privileges to different individuals depending on their roles and responsibilities in an organization.
low-impact system [FIPS 200]	A system in which all three security objectives (i.e., confidentiality, integrity, and availability) are assigned a FIPS Publication 199 potential impact value of low.
malicious code	Software or firmware intended to perform an unauthorized process that will have adverse impacts on the confidentiality, integrity, or availability of a system. A virus, worm, Trojan horse, or other code-based entity that infects a host. Spyware and some forms of adware are also examples of malicious code.
managed interface	An interface within a system that provides boundary protection capabilities using automated mechanisms or devices.
mandatory access control	An access control policy that is uniformly enforced across all subjects and objects within a system. A subject that has been granted access to information is constrained from: passing the information to unauthorized subjects or objects; granting its privileges to other subjects; changing one or more security attributes on subjects, objects, the system, or system components; choosing the security attributes to be associated with newly created or modified objects; or changing the rules for governing access control. Organization-defined subjects may explicitly be granted organization-defined privileges (i.e., they are trusted subjects) such that they are not limited by some or all of the above constraints. Mandatory access control is considered a type of nondiscretionary access control.
marking	See <i>security marking</i> .
matching agreement [OMB A-108]	A written agreement between a recipient agency and a source agency (or a non-Federal agency) that is required by the Privacy Act for parties engaging in a matching program.
media [FIPS 200]	Physical devices or writing surfaces including magnetic tapes, optical disks, magnetic disks, Large-Scale Integration memory chips, and printouts (but excluding display media) onto which information is recorded, stored, or printed within a system.
metadata	Information that describes the characteristics of data, including structural metadata that describes data structures (i.e., data format, syntax, semantics) and descriptive metadata that describes data contents (i.e., security labels).

mobile code	Software programs or parts of programs obtained from remote systems, transmitted across a network, and executed on a local system without explicit installation or execution by the recipient.
mobile code technologies	Software technologies that provide the mechanisms for the production and use of mobile code.
mobile device	A portable computing device that has a small form factor such that it can easily be carried by a single individual; is designed to operate without a physical connection (e.g., wirelessly transmit or receive information); possesses local, non-removable data storage; and is powered on for extended periods of time with a self-contained power source. Mobile devices may also include voice communication capabilities, on-board sensors that allow the device to capture (e.g., photograph, video, record, or determine location) information, and/or built-in features for synchronizing local data with remote locations. Examples include smart phones, tablets, and e-readers.
moderate-impact system [FIPS 200]	A system in which at least one security objective (i.e., confidentiality, integrity, or availability) is assigned a FIPS Publication 199 potential impact value of moderate and no security objective is assigned a potential impact value of high.
multi-factor authentication [SP 800-63-3]	An authentication system or an authenticator that requires more than one authentication factor for successful authentication. Multi-factor authentication can be performed using a single authenticator that provides more than one factor or by a combination of authenticators that provide different factors. The three authentication factors are something you know, something you have, and something you are. See <i>authenticator</i> .
multilevel security [CNSSI 4009]	Concept of processing information with different classifications and categories that simultaneously permits access by users with different security clearances and denies access to users who lack authorization.
multiple security levels [CNSSI 4009]	Capability of a system that is trusted to contain, and maintain separation between, resources (particularly stored data) of different security domains.

national security system [OMB A-130]	Any system (including any telecommunications system) used or operated by an agency or by a contractor of an agency, or other organization on behalf of an agency—(i) the function, operation, or use of which involves intelligence activities; involves cryptologic activities related to national security; involves command and control of military forces; involves equipment that is an integral part of a weapon or weapons system; or is critical to the direct fulfillment of military or intelligence missions (excluding a system that is to be used for routine administrative and business applications, for example, payroll, finance, logistics, and personnel management applications); or (ii) is protected at all times by procedures established for information that have been specifically authorized under criteria established by an Executive Order or an Act of Congress to be kept classified in the interest of national defense or foreign policy.
network	A system implemented with a collection of connected components. Such components may include routers, hubs, cabling, telecommunications controllers, key distribution centers, and technical control devices.
network access	Access to a system by a user (or a process acting on behalf of a user) communicating through a network, including a local area network, a wide area network, and the Internet.
nonce [SP 800-63-3]	A value used in security protocols that is never repeated with the same key. For example, nonces used as challenges in challenge-response authentication protocols are not repeated until the authentication keys are changed. Otherwise, there is a possibility of a replay attack.
nondiscretionary access control	See <i>mandatory access control</i> .
nonlocal maintenance	Maintenance activities conducted by individuals who communicate through either an internal or external network.
non-organizational user	A user who is not an organizational user (including public users).
non-repudiation	Protection against an individual who falsely denies having performed a certain action and provides the capability to determine whether an individual took a certain action, such as creating information, sending a message, approving information, or receiving a message.
NSA-approved cryptography	Cryptography that consists of an approved algorithm, an implementation that has been approved for the protection of classified information and/or controlled unclassified information in a specific environment, and a supporting key management infrastructure.

object	Passive system-related entity, including devices, files, records, tables, processes, programs, and domains that contain or receive information. Access to an object (by a subject) implies access to the information it contains. See <i>subject</i> .
operations security [CNSSI 4009]	Systematic and proven process by which potential adversaries can be denied information about capabilities and intentions by identifying, controlling, and protecting generally unclassified evidence of the planning and execution of sensitive activities. The process involves five steps: identification of critical information, analysis of threats, analysis of vulnerabilities, assessment of risks, and application of appropriate countermeasures.
organization [FIPS 200, Adapted]	An entity of any size, complexity, or positioning within an organizational structure, including federal agencies, private enterprises, academic institutions, state, local, or tribal governments, or as appropriate, any of their operational elements.
organization-defined control parameter	The variable part of a control or control enhancement that is instantiated by an organization during the tailoring process by either assigning an organization-defined value or selecting a value from a predefined list provided as part of the control or control enhancement. See <i>assignment operation</i> and <i>selection operation</i> .
organizational user	An organizational employee or an individual whom the organization deems to have equivalent status of an employee, including a contractor, guest researcher, or individual detailed from another organization. Policies and procedures for granting the equivalent status of employees to individuals may include need-to-know, relationship to the organization, and citizenship.
overlay [OMB A-130]	A specification of security or privacy controls, control enhancements, supplemental guidance, and other supporting information employed during the tailoring process, that is intended to complement (and further refine) security control baselines. The overlay specification may be more stringent or less stringent than the original security control baseline specification and can be applied to multiple information systems. See <i>tailoring</i> .
parameter	See <i>organization-defined control parameter</i> .
penetration testing	A test methodology in which assessors, typically working under specific constraints, attempt to circumvent or defeat the security features of a system.

periods processing	A mode of system operation in which information of different sensitivities is processed at distinctly different times by the same system with the system being properly purged or sanitized between periods.
personally identifiable information [OMB A-130]	Information that can be used to distinguish or trace an individual's identity, either alone or when combined with other information that is linked or linkable to a specific individual.
personally identifiable information processing [ISO/IEC 29100, Adapted]	An operation or set of operations performed upon personally identifiable information that can include, but is not limited to, the collection, retention, logging, generation, transformation, use, disclosure, transfer, and disposal of personally identifiable information.
personally identifiable information processing permissions	The requirements for how personally identifiable information can be processed or the conditions under which personally identifiable information can be processed.
personnel security	The discipline of assessing the conduct, integrity, judgment, loyalty, reliability, and stability of individuals for duties and responsibilities that require trustworthiness.
physical access control system [SP 800-116]	An electronic system that controls the ability of people or vehicles to enter a protected area by means of authentication and authorization at access control points.
plan of action and milestones	A document that identifies tasks that need to be accomplished. It details resources required to accomplish the elements of the plan, milestones for meeting the tasks, and the scheduled completion dates for the milestones.
portable storage device	A system component that can communicate with and be added to or removed from a system or network and that is limited to data storage—including text, video, audio or image data—as its primary function (e.g., optical discs, external or removable hard drives, external or removable solid-state disk drives, magnetic or optical tapes, flash memory devices, flash memory cards, and other external or removable disks).
potential impact [FIPS 199]	The loss of confidentiality, integrity, or availability could be expected to have a limited adverse effect (FIPS Publication 199 low); a serious adverse effect (FIPS Publication 199 moderate); or a severe or catastrophic adverse effect (FIPS Publication 199 high) on organizational operations, organizational assets, or individuals.
privacy architecture [SP 800-37]	An embedded, integral part of the enterprise architecture that describes the structure and behavior for an enterprise's privacy protection processes, technical measures, personnel and organizational sub-units, showing their alignment with the enterprise's mission and strategic plans.

privacy control [OMB A-130]	The administrative, technical, and physical safeguards employed within an agency to ensure compliance with applicable privacy requirements and manage privacy risks.
privacy control baseline	The set of privacy controls selected based on the privacy selection criteria that provide a starting point for the tailoring process.
privacy domain	A domain that implements a privacy policy.
privacy impact assessment [OMB A-130]	An analysis of how information is handled to ensure handling conforms to applicable legal, regulatory, and policy requirements regarding privacy; to determine the risks and effects of creating, collecting, using, processing, storing, maintaining, disseminating, disclosing, and disposing of information in identifiable form in an electronic information system; and to examine and evaluate protections and alternate processes for handling information to mitigate potential privacy concerns. A privacy impact assessment is both an analysis and a formal document detailing the process and the outcome of the analysis.
privacy plan [OMB A-130]	A formal document that details the privacy controls selected for an information system or environment of operation that are in place or planned for meeting applicable privacy requirements and managing privacy risks, details how the controls have been implemented, and describes the methodologies and metrics that will be used to assess the controls.
privacy program plan [OMB A-130]	A formal document that provides an overview of an agency's privacy program, including a description of the structure of the privacy program, the resources dedicated to the privacy program, the role of the Senior Agency Official for Privacy and other privacy officials and staff, the strategic goals and objectives of the privacy program, and the program management controls and common controls in place or planned for meeting applicable privacy requirements and managing privacy risks.
privileged account	A system account with the authorizations of a privileged user.
privileged command	A human-initiated command executed on a system that involves the control, monitoring, or administration of the system, including security functions and associated security-relevant information.
privileged user [CNSSI 4009]	A user that is authorized (and therefore, trusted) to perform security-relevant functions that ordinary users are not authorized to perform.

protected distribution system [CNSSI 4009]	Wire line or fiber optic system that includes adequate safeguards and/or countermeasures (e.g., acoustic, electric, electromagnetic, and physical) to permit its use for the transmission of unencrypted information through an area of lesser classification or control.
provenance	The chronology of the origin, development, ownership, location, and changes to a system or system component and associated data. It may also include the personnel and processes used to interact with or make modifications to the system, component, or associated data.
public key infrastructure [CNSSI 4009]	The architecture, organization, techniques, practices, and procedures that collectively support the implementation and operation of a certificate-based public key cryptographic system. Framework established to issue, maintain, and revoke public key certificates.
purge [SP 800-88]	A method of sanitization that applies physical or logical techniques that render target data recovery infeasible using state of the art laboratory techniques.
reciprocity [SP 800-37]	Agreement among participating organizations to accept each other's security assessments to reuse system resources and/or to accept each other's assessed security posture to share information.
records [OMB A-130]	All recorded information, regardless of form or characteristics, made or received by a Federal agency under Federal law or in connection with the transaction of public business and preserved or appropriate for preservation by that agency or its legitimate successor as evidence of the organization, functions, policies, decisions, procedures, operations, or other activities of the United States Government or because of the informational value of data in them.
red team exercise	An exercise, reflecting real-world conditions that is conducted as a simulated adversarial attempt to compromise organizational missions or business processes and to provide a comprehensive assessment of the security capabilities of an organization and its systems.
reference monitor	A set of design requirements on a reference validation mechanism that, as a key component of an operating system, enforces an access control policy over all subjects and objects. A reference validation mechanism is always invoked (i.e., complete mediation), tamperproof, and small enough to be subject to analysis and tests, the completeness of which can be assured (i.e., verifiable).

regrader [CNSSI 4009]	A trusted process explicitly authorized to re-classify and re-label data in accordance with a defined policy exception. Untrusted or unauthorized processes are such actions by the security policy.
remote access	Access to an organizational system by a user (or a process acting on behalf of a user) communicating through an external network.
remote maintenance	Maintenance activities conducted by individuals communicating through an external network.
replay attack [SP 800-63-3]	An attack in which the Attacker is able to replay previously captured messages (between a legitimate Claimant and a Verifier) to masquerade as that Claimant to the Verifier or vice versa.
replay resistance	Protection against the capture of transmitted authentication or access control information and its subsequent retransmission with the intent of producing an unauthorized effect or gaining unauthorized access.
resilience [OMB A-130]	The ability of an information system to operate under adverse conditions or stress, even if in a degraded or debilitated state, while maintaining essential operational capabilities, and to recover to an effective operational posture in a time frame consistent with mission needs.
restricted data [ATOM54]	All data concerning (i) design, manufacture, or utilization of atomic weapons; (ii) the production of special nuclear material; or (iii) the use of special nuclear material in the production of energy, but shall not include data declassified or removed from the Restricted Data category pursuant to Section 142 [of the Atomic Energy Act of 1954].
risk [OMB A-130]	A measure of the extent to which an entity is threatened by a potential circumstance or event, and typically is a function of: (i) the adverse impact, or magnitude of harm, that would arise if the circumstance or event occurs; and (ii) the likelihood of occurrence.
risk assessment [SP 800-39] [IR 8062, adapted]	The process of identifying risks to organizational operations (including mission, functions, image, reputation), organizational assets, individuals, other organizations, and the Nation, resulting from the operation of a system. Risk management includes threat and vulnerability analyses as well as analyses of adverse effects on individuals arising from information processing and considers mitigations provided by security and privacy controls planned or in place. Synonymous with <i>risk analysis</i>.

risk executive (function) [SP 800-37]	An individual or group within an organization that helps to ensure that security risk-related considerations for individual systems, to include the authorization decisions for those systems, are viewed from an organization-wide perspective with regard to the overall strategic goals and objectives of the organization in carrying out its mission and business functions; and managing risk from individual systems is consistent across the organization, reflects organizational risk tolerance, and is considered along with other organizational risks affecting mission or business success.
risk management [OMB A-130]	The program and supporting processes to manage risk to agency operations (including mission, functions, image, reputation), agency assets, individuals, other organizations, and the Nation, and includes: establishing the context for risk-related activities; assessing risk; responding to risk once determined; and monitoring risk over time.
risk mitigation [CNSSI 4009]	Prioritizing, evaluating, and implementing the appropriate risk-reducing controls/countermeasures recommended from the risk management process.
risk response [OMB A-130]	Accepting, avoiding, mitigating, sharing, or transferring risk to agency operations, agency assets, individuals, other organizations, or the Nation.
risk tolerance [SP 800-39]	The level of risk or the degree of uncertainty that is acceptable to an organization.
role-based access control	Access control based on user roles (i.e., a collection of access authorizations that a user receives based on an explicit or implicit assumption of a given role). Role permissions may be inherited through a role hierarchy and typically reflect the permissions needed to perform defined functions within an organization. A given role may apply to a single individual or to several individuals.
runtime	The period during which a computer program is executing.
sanitization [SP 800-88]	A process to render access to target data on the media infeasible for a given level of effort. Clear, purge, and destroy are actions that can be taken to sanitize media.
scoping considerations	A part of tailoring guidance that provides organizations with specific considerations on the applicability and implementation of security and privacy controls in the control baselines. Considerations include policy or regulatory, technology, physical infrastructure, system component allocation, public access, scalability, common control, operational or environmental, and security objective.

security [CNSSI 4009]	A condition that results from the establishment and maintenance of protective measures that enable an organization to perform its mission or critical functions despite risks posed by threats to its use of systems. Protective measures may involve a combination of deterrence, avoidance, prevention, detection, recovery, and correction that should form part of the organization's risk management approach.
security attribute	An abstraction that represents the basic properties or characteristics of an entity with respect to safeguarding information. Typically associated with internal data structures—including records, buffers, and files within the system—and used to enable the implementation of access control and flow control policies; reflect special dissemination, handling or distribution instructions; or support other aspects of the information security policy.
security categorization	The process of determining the security category for information or a system. Security categorization methodologies are described in CNSS Instruction 1253 for national security systems and in FIPS Publication 199 for other than national security systems. See <i>security category</i> .
security category [OMB A-130]	The characterization of information or an information system based on an assessment of the potential impact that a loss of confidentiality, integrity, or availability of such information or information system would have on agency operations, agency assets, individuals, other organizations, and the Nation.
security control [OMB A-130]	The safeguards or countermeasures prescribed for an information system or an organization to protect the confidentiality, integrity, and availability of the system and its information.
security control baseline [OMB A-130]	The set of minimum security controls defined for a low-impact, moderate-impact, or high-impact information system.
security domain [CNSSI 4009]	A domain that implements a security policy and is administered by a single authority.
security functionality	The security-related features, functions, mechanisms, services, procedures, and architectures implemented within organizational information systems or the environments in which those systems operate.
security functions	The hardware, software, or firmware of the system responsible for enforcing the system security policy and supporting the isolation of code and data on which the protection is based.
security impact analysis [SP 800-128]	The analysis conducted by qualified staff within an organization to determine the extent to which changes to the system affect the security posture of the system.

security kernel [CNSSI 4009]	Hardware, firmware, and software elements of a trusted computing base implementing the reference monitor concept. Security kernel must mediate all accesses, be protected from modification, and be verifiable as correct.
security label	The means used to associate a set of security attributes with a specific information object as part of the data structure for that object.
security marking	The means used to associate a set of security attributes with objects in a human-readable form in order to enable organizational, process-based enforcement of information security policies.
security objective [FIPS 199]	Confidentiality, integrity, or availability.
security plan	A formal document that provides an overview of the security requirements for an information system or an information security program and describes the security controls in place or planned for meeting those requirements. The system security plan describes the system components that are included within the system, the environment in which the system operates, how the security requirements are implemented, and the relationships with or connections to other systems. <i>See system security plan.</i>
security policy [SP 800-160-1 adapted]	A set of criteria for the provision of security services. A set of rules that governs all aspects of security-relevant system and system component behavior.
security policy filter	A hardware and/or software component that performs one or more of the following functions: content verification to ensure the data type of the submitted content; content inspection to analyze the submitted content and verify that complies with a defined policy; malicious content checker that evaluates the content for malicious code; suspicious activity checker that evaluates or executes the content in a safe manner, such as in a sandbox or detonation chamber and monitors for suspicious activity; or content sanitization, cleansing, and transformation, which modifies the submitted content to comply with a defined policy.

security requirement [FIPS 200, Adapted]	A requirement levied on an information system or an organization that is derived from applicable laws, executive orders, directives, regulations, policies, standards, procedures, or mission/business needs to ensure the confidentiality, integrity, and availability of information that is being processed, stored, or transmitted. <i>Note:</i> Security requirements can be used in a variety of contexts from high-level policy-related activities to low-level implementation-related activities in system development and engineering disciplines.
security service [SP 800-160-1]	A security capability or function provided by an entity that supports one or more security objectives.
security-relevant information	Information within the system that can potentially impact the operation of security functions or the provision of security services in a manner that could result in failure to enforce the system security policy or maintain isolation of code and data.
selection operation	A control parameter that allows an organization to select a value from a list of predefined values provided as part of the control or control enhancement (e.g., selecting to either restrict an action or prohibit an action). <i>See assignment operation and organization-defined control parameter.</i>
senior agency information security officer	Official responsible for carrying out the Chief Information Officer responsibilities under FISMA and serving as the Chief Information Officer's primary liaison to the agency's authorizing officials, information system owners, and information system security officers. <i>Note:</i> Organizations subordinate to federal agencies may use the term <i>senior information security officer</i> or <i>chief information security officer</i> to denote individuals who fill positions with similar responsibilities to senior agency information security officers.
senior agency official for privacy [OMB A-130]	Senior official, designated by the head of each agency, who has agency-wide responsibility for privacy, including implementation of privacy protections; compliance with Federal laws, regulations, and policies relating to privacy; management of privacy risks at the agency; and a central policy-making role in the agency's development and evaluation of legislative, regulatory, and other policy proposals.
senior information security officer	<i>See senior agency information security officer.</i>
sensitive compartmented information [CNSSI 4009]	Classified information concerning or derived from intelligence sources, methods, or analytical processes, which is required to be handled within formal access control systems established by the Director of National Intelligence.

service-oriented architecture	A set of principles and methodologies for designing and developing software in the form of interoperable services. These services are well-defined business functions that are built as software components (i.e., discrete pieces of code and/or data structures) that can be reused for different purposes.
shared control	A security or privacy control that is implemented for an information system in part as a common control and in part as a system-specific control. See <i>hybrid control</i> .
software [CNSSI 4009]	Computer programs and associated data that may be dynamically written or modified during execution.
spam	The abuse of electronic messaging systems to indiscriminately send unsolicited bulk messages.
special access program [CNSSI 4009]	A program established for a specific class of classified information that imposes safeguarding and access requirements that exceed those normally required for information at the same classification level.
split tunneling	The process of allowing a remote user or device to establish a non-remote connection with a system and simultaneously communicate via some other connection to a resource in an external network. This method of network access enables a user to access remote devices, and simultaneously, access uncontrolled networks.
spyware	Software that is secretly or surreptitiously installed into an information system to gather information on individuals or organizations without their knowledge; a type of malicious code.
subject	An individual, process, or device that causes information to flow among objects or change to the system state. Also see <i>object</i> .
subsystem	A major subdivision or component of an information system consisting of information, information technology, and personnel that performs one or more specific functions.
supplier	Organization or individual that enters into an agreement with the acquirer or integrator for the supply of a product or service. This includes all suppliers in the supply chain, developers or manufacturers of systems, system components, or system services; systems integrators; vendors; product resellers; and third party partners.
supply chain	Linked set of resources and processes between and among multiple tiers of organizations, each of which is an acquirer, that begins with the sourcing of products and services and extends through their life cycle.

supply chain element	Organizations, entities, or tools employed for the research and development, design, manufacturing, acquisition, delivery, integration, operations and maintenance, and disposal of systems and system components.
supply chain risk	The potential for harm or compromise that arises as a result of security risks from suppliers, their supply chains, and their products or services. Supply chain risks include exposures, threats, and vulnerabilities associated with the products and services traversing the supply chain as well as the exposures, threats, and vulnerabilities to the supply chain.
supply chain risk assessment	A systematic examination of supply chain risks, likelihoods of their occurrence, and potential impacts.
supply chain risk management	A systematic process for managing cyber supply chain risk exposures, threats, and vulnerabilities throughout the supply chain and developing risk response strategies to the risks presented by the supplier, the supplied products and services, or the supply chain.
system [CNSSI 4009]	Any organized assembly of resources and procedures united and regulated by interaction or interdependence to accomplish a set of specific functions. <i>Note:</i> Systems also include specialized systems such as industrial control systems, telephone switching and private branch exchange (PBX) systems, and environmental control systems.
[ISO 15288]	Combination of interacting elements organized to achieve one or more stated purposes. <i>Note 1:</i> There are many types of systems. Examples include: general and special-purpose information systems; command, control, and communication systems; crypto modules; central processing unit and graphics processor boards; industrial control systems; flight control systems; weapons, targeting, and fire control systems; medical devices and treatment systems; financial, banking, and merchandising transaction systems; and social networking systems. <i>Note 2:</i> The interacting elements in the definition of system include hardware, software, data, humans, processes, facilities, materials, and naturally occurring physical entities. <i>Note 3:</i> System-of-systems is included in the definition of system.
system component [SP 800-128]	A discrete identifiable information technology asset that represents a building block of a system and may include hardware, software, and firmware.
system of records [USC 552]	A group of any records under the control of any agency from which information is retrieved by the name of the individual or by some identifying number, symbol, or other identifying particular assigned to the individual.
system of records notice [OMB A-108]	The notice(s) published by an agency in the <i>Federal Register</i> upon the establishment and/or modification of a system of records describing the existence and character of the system.

system owner (or program manager)	Official responsible for the overall procurement, development, integration, modification, operation, and maintenance of a system.
system security officer [SP 800-37]	Individual with assigned responsibility for maintaining the appropriate operational security posture for a system or program.
system security plan	See <i>security plan</i> .
system service	A capability provided by a system that facilitates information processing, storage, or transmission.
system-related security risk [SP 800-30]	Risk that arises through the loss of confidentiality, integrity, or availability of information or systems and that considers impacts to the organization (including assets, mission, functions, image, or reputation), individuals, other organizations, and the Nation. See <i>risk</i> .
system-specific control [OMB A-130]	A security or privacy control for an information system that is implemented at the system level and is not inherited by any other information system.
systems engineering [SP 800-160-1]	An engineering discipline whose responsibility is creating and executing an interdisciplinary process to ensure that the customer and all other stakeholder needs are satisfied in a high-quality, trustworthy, cost-efficient, and schedule-compliant manner throughout a system's entire life cycle.
systems security engineering [SP 800-160-1]	A specialty engineering field strongly related to systems engineering. It applies scientific, engineering, and information assurance principles to deliver trustworthy systems that satisfy stakeholder requirements within their established risk tolerance.
tailored control baseline	A set of controls that result from the application of tailoring guidance to a control baseline. See <i>tailoring</i> .
tailoring	The process by which security control baselines are modified by: identifying and designating common controls, applying scoping considerations on the applicability and implementation of baseline controls, selecting compensating security controls, assigning specific values to organization-defined security control parameters, supplementing baselines with additional security controls or control enhancements, and providing additional specification information for control implementation.
tampering [CNSSI 4009]	An intentional but unauthorized act resulting in the modification of a system, components of systems, its intended behavior, or data.

threat [SP 800-30]	Any circumstance or event with the potential to adversely impact organizational operations, organizational assets, individuals, other organizations, or the Nation through a system via unauthorized access, destruction, disclosure, modification of information, and/or denial of service.
threat assessment [CNSSI 4009]	Formal description and evaluation of threat to an information system.
threat modeling [SP 800-154]	A form of risk assessment that models aspects of the attack and defense sides of a logical entity, such as a piece of data, an application, a host, a system, or an environment.
threat source [FIPS 200]	The intent and method targeted at the intentional exploitation of a vulnerability or a situation and method that may accidentally trigger a vulnerability. See <i>threat agent</i> .
transmission [CNSSI 4009]	The state that exists when information is being electronically sent from one location to one or more other locations.
trusted path	A mechanism by which a user (through an input device) can communicate directly with the security functions of the system with the necessary confidence to support the system security policy. This mechanism can only be activated by the user or the security functions of the system and cannot be imitated by untrusted software.
trustworthiness [CNSSI 4009]	The attribute of a person or enterprise that provides confidence to others of the qualifications, capabilities, and reliability of that entity to perform specific tasks and fulfill assigned responsibilities.
trustworthiness (system)	The degree to which an information system (including the information technology components that are used to build the system) can be expected to preserve the confidentiality, integrity, and availability of the information being processed, stored, or transmitted by the system across the full range of threats. A trustworthy information system is believed to operate within defined levels of risk despite the environmental disruptions, human errors, structural failures, and purposeful attacks that are expected to occur in its environment of operation.
user	Individual, or (system) process acting on behalf of an individual, authorized to access a system. See <i>organizational user</i> and <i>non-organizational user</i> .
virtual private network [CNSSI 4009]	Protected information system link utilizing tunneling, security controls, and endpoint address translation giving the impression of a dedicated line.

vulnerability [SP 800-30]	Weakness in an information system, system security procedures, internal controls, or implementation that could be exploited or triggered by a threat source.
vulnerability analysis	See <i>vulnerability assessment</i> .
vulnerability assessment [CNSSI 4009]	Systematic examination of an information system or product to determine the adequacy of security measures, identify security deficiencies, provide data from which to predict the effectiveness of proposed security measures, and confirm the adequacy of such measures after implementation.

APPENDIX B

ACRONYMS

COMMON ABBREVIATIONS

ABAC	Attribute-Based Access Control
API	Application Programming Interface
APT	Advanced Persistent Threat
BGP	Border Gateway Protocol
BIOS	Basic Input/Output System
CA	Certificate Authority/Certificate Authorities
CAC	Common Access Card
CAVP	Cryptographic Algorithm Validation Program
CD	Compact Disc
CD-R	Compact Disc-Recordable
CIPSEA	Confidential Information Protection and Statistical Efficiency Act
CIRT	Computer Incident Response Team
CISA	Cybersecurity and Infrastructure Security Agency
CMVP	Cryptographic Module Validation Program
CNSSD	Committee on National Security Systems Directive
CNSSI	Committee on National Security Systems Instruction
CNSSP	Committee on National Security Systems Policy
CONOPS	Concept of Operations
CUI	Controlled Unclassified Information
CVE	Common Vulnerabilities and Exposures
CVSS	Common Vulnerability Scoring System
CWE	Common Weakness Enumeration
DHCP	Dynamic Host Configuration Protocol
DMZ	Demilitarized Zone
DNS	Domain Name System
DNSSEC	Domain Name System Security Extensions
DoD	Department of Defense
DSB	Defense Science Board
DVD	Digital Versatile Disc

DVD-R	Digital Versatile Disc-Recordable
EAP	Extensible Authentication Protocol
EMP	Electromagnetic Pulse
EMSEC	Emissions Security
FASC	Federal Acquisition Security Council
FBCA	Federal Bridge Certification Authority
FCC	Federal Communications Commission
FICAM	Federal Identity, Credential, and Access Management
FIPPs	Fair Information Practice Principles
FIPS	Federal Information Processing Standards
FISMA	Federal Information Security Modernization Act
FOCI	Foreign Ownership, Control, or Influence
FOIA	Freedom of Information Act
FTP	File Transfer Protocol
GMT	Greenwich Mean Time
GPS	Global Positioning System
GSA	General Services Administration
HSPD	Homeland Security Presidential Directive
HTTP	Hypertext Transfer Protocol
ICS	Industrial Control System
IEEE	Institute of Electrical and Electronics Engineers
I/O	Input/Output
IOC	Indicators of Compromise
IoT	Internet of Things
IP	Internet Protocol
IR	Interagency Report or Internal Report
ISAC	Information Sharing and Analysis Centers
ISAO	Information Sharing and Analysis Organizations
IT	Information Technology
ITL	Information Technology Laboratory
MAC	Media Access Control
MLS	Multilevel Secure
MTTF	Mean Time To Failure

NARA	National Archives and Records Administration
NATO	North Atlantic Treaty Organization
NDA	Non-Disclosure Agreement
NIAP	National Information Assurance Partnership
NICE	National Initiative for Cybersecurity Education
NIST	National Institute of Standards and Technology
NOFORN	Not Releasable to Foreign Nationals
NSA	National Security Agency
NVD	National Vulnerability Database
ODNI	Office of the Director of National Intelligence
OMB	Office of Management and Budget
OPM	Office of Personnel Management
OPSEC	Operation Security
OVAL	Open Vulnerability and Assessment Language
PDF	Portable Document Format
PDS	Position Designation System
PII	Personally Identifiable Information
PIN	Personal Identification Number
PIV	Personal Identity Verification
PIV-I	Personal Identity Verification-Interoperable
PKI	Public Key Infrastructure
RBAC	Role-Based Access Control
RD	Restricted Data
RFID	Radio-Frequency Identification
RFP	Request For Proposal
RPKI	Resource Public Key Infrastructure
SAP	Special Access Program
SCAP	Security Content Automation Protocol
SCI	Sensitive Compartmented Information
SCIF	Sensitive Compartmented Information Facility
SCRM	Supply Chain Risk Management
SDLC	System Development Life Cycle
SIEM	Security Information and Event Management

SME	Subject Matter Expert
SMTP	Simple Mail Transfer Protocol
SOC	Security Operations Center
SP	Special Publication
STIG	Security Technical Implementation Guide
SWID	Software Identification
TCP	Transmission Control Protocol
TCP/IP	Transmission Control Protocol/Internet Protocol
TIC	Trusted Internet Connections
TLS	Transport Layer Security
TPM	Trusted Platform Module
TSP	Telecommunications Service Priority
UEFI	Unified Extensible Firmware Interface
UPS	Uninterruptible Power Supply
USGCB	United States Government Configuration Baseline
USB	Universal Serial Bus
UTC	Coordinated Universal Time
VoIP	Voice over Internet Protocol
VPN	Virtual Private Network
WORM	Write-Once, Read-Many
XML	Extensible Markup Language

APPENDIX C

CONTROL SUMMARIES

IMPLEMENTATION, WITHDRAWAL, AND ASSURANCE DESIGNATIONS

Tables C-1 through C-20 provide a summary of the security and privacy controls and control enhancements in [Chapter Three](#). Each table focuses on a different control family.

- A control or control enhancement that has been withdrawn from the control catalog is indicated by a “W” and an explanation of the control or control enhancement disposition in light gray text.
- A control or control enhancement that is typically implemented by an information system through technical means is indicated by an “S” in the *implemented by* column.
- A control or control enhancement that is typically implemented by an organization (i.e., by an individual through nontechnical means) is indicated by an “O” in the *implemented by* column.³⁵
- A control or control enhancement that can be implemented by an organization, a system, or a combination of the two is indicated by an “O/S.”
- A control or control enhancement marked with a “V” in the *assurance* column indicates the control or control enhancement contributes to the grounds for confidence that a security or privacy claim has been or will be achieved.³⁶

Each control and control enhancement in Tables C-1 through C-20 is hyperlinked to the text for that control and control enhancement in [Chapter Three](#).

Families of controls contain base controls and control enhancements, which are directly related to their base controls. Control enhancements either add functionality or specificity to a base control or increase the strength of a base control. In both cases, control enhancements are used in systems and environments of operation that require greater protection than provided by the base control. This increased protection is required due to the potential adverse organizational or individual impacts or when organizations require additions to the base control functionality or assurance based on organizational assessments of risk. The use of control enhancements **always** requires the use of the base control.

The families are arranged in alphabetical order, while the controls and control enhancements within each family are arranged in numerical order. The alphabetical or numerical order of the families, controls, and control enhancements does **not** imply any type of prioritization, level of importance, or order in which the controls or control enhancements are to be implemented.

³⁵ The indication that a certain control or control enhancement is implemented by a *system* or by an *organization* in Tables C-1 through C-20 is notional. Organizations have the flexibility to implement their selected controls and control enhancements in the most cost-effective and efficient manner while simultaneously complying with the intent of the controls or control enhancements. In certain situations, a control or control enhancement may be implemented by the system, the organization, or a combination of the two entities.

³⁶ Assurance is a critical aspect in determining the trustworthiness of systems. Assurance is the measure of confidence that the security and privacy functions, features, practices, policies, procedures, mechanisms, and architecture of organizational systems accurately mediate and enforce established security and privacy policies.

TABLE C-1: ACCESS CONTROL FAMILY

CONTROL NUMBER	CONTROL NAME CONTROL ENHANCEMENT NAME	IMPLEMENTED BY	ASSURANCE
AC-1	Policy and Procedures	O	V
AC-2	Account Management	O	
AC-2(1)	AUTOMATED SYSTEM ACCOUNT MANAGEMENT	O	
AC-2(2)	AUTOMATED TEMPORARY AND EMERGENCY ACCOUNT MANAGEMENT	S	
AC-2(3)	DISABLE ACCOUNTS	S	
AC-2(4)	AUTOMATED AUDIT ACTIONS	S	
AC-2(5)	INACTIVITY LOGOUT	O/S	
AC-2(6)	DYNAMIC PRIVILEGE MANAGEMENT	S	
AC-2(7)	PRIVILEGED USER ACCOUNTS	O	
AC-2(8)	DYNAMIC ACCOUNT MANAGEMENT	S	
AC-2(9)	RESTRICTIONS ON USE OF SHARED AND GROUP ACCOUNTS	O	
AC-2(10)	SHARED AND GROUP ACCOUNT CREDENTIAL CHANGE	W: Incorporated into AC-2k.	
AC-2(11)	USAGE CONDITIONS	S	
AC-2(12)	ACCOUNT MONITORING FOR ATYPICAL USAGE	O/S	
AC-2(13)	DISABLE ACCOUNTS FOR HIGH-RISK INDIVIDUALS	O	
AC-3	Access Enforcement	S	
AC-3(1)	RESTRICTED ACCESS TO PRIVILEGED FUNCTIONS	W: Incorporated into AC-6.	
AC-3(2)	DUAL AUTHORIZATION	S	
AC-3(3)	MANDATORY ACCESS CONTROL	S	
AC-3(4)	DISCRETIONARY ACCESS CONTROL	S	
AC-3(5)	SECURITY-RELEVANT INFORMATION	S	
AC-3(6)	PROTECTION OF USER AND SYSTEM INFORMATION	W: Incorporated into MP-4 and SC-28.	
AC-3(7)	ROLE-BASED ACCESS CONTROL	O/S	
AC-3(8)	REVOCATION OF ACCESS AUTHORIZATIONS	O/S	
AC-3(9)	CONTROLLED RELEASE	O/S	
AC-3(10)	AUDITED OVERRIDE OF ACCESS CONTROL MECHANISMS	O	
AC-3(11)	RESTRICT ACCESS TO SPECIFIC INFORMATION TYPES	S	
AC-3(12)	ASSERT AND ENFORCE APPLICATION ACCESS	S	
AC-3(13)	ATTRIBUTE-BASED ACCESS CONTROL	S	
AC-3(14)	INDIVIDUAL ACCESS	S	
AC-3(15)	DISCRETIONARY AND MANDATORY ACCESS CONTROL	S	
AC-4	Information Flow Enforcement	S	
AC-4(1)	OBJECT SECURITY AND PRIVACY ATTRIBUTES	S	
AC-4(2)	PROCESSING DOMAINS	S	
AC-4(3)	DYNAMIC INFORMATION FLOW CONTROL	S	
AC-4(4)	FLOW CONTROL OF ENCRYPTED INFORMATION	S	
AC-4(5)	EMBEDDED DATA TYPES	S	
AC-4(6)	METADATA	S	
AC-4(7)	ONE-WAY FLOW MECHANISMS	S	
AC-4(8)	SECURITY AND PRIVACY POLICY FILTERS	S	
AC-4(9)	HUMAN REVIEWS	O/S	
AC-4(10)	ENABLE AND DISABLE SECURITY OR PRIVACY POLICY FILTERS	S	

CONTROL NUMBER	CONTROL NAME CONTROL ENHANCEMENT NAME	IMPLEMENTED BY	ASSURANCE
AC-4(11)	CONFIGURATION OF SECURITY OR PRIVACY POLICY FILTERS	S	
AC-4(12)	DATA TYPE IDENTIFIERS	S	
AC-4(13)	DECOMPOSITION INTO POLICY-RELEVANT SUBCOMPONENTS	S	
AC-4(14)	SECURITY OR PRIVACY POLICY FILTER CONSTRAINTS	S	
AC-4(15)	DETECTION OF UNSANCTIONED INFORMATION	S	
AC-4(16)	INFORMATION TRANSFERS ON INTERCONNECTED SYSTEMS	W: Incorporated into AC-4.	
AC-4(17)	DOMAIN AUTHENTICATION	S	
AC-4(18)	SECURITY ATTRIBUTE BINDING	W: Incorporated into AC-16.	
AC-4(19)	VALIDATION OF METADATA	S	
AC-4(20)	APPROVED SOLUTIONS	O	
AC-4(21)	PHYSICAL OR LOGICAL SEPARATION OF INFORMATION FLOWS	O/S	
AC-4(22)	ACCESS ONLY	S	
AC-4(23)	MODIFY NON-RELEASABLE INFORMATION	O/S	
AC-4(24)	INTERNAL NORMALIZED FORMAT	S	
AC-4(25)	DATA SANITIZATION	S	
AC-4(26)	AUDIT FILTERING ACTIONS	O/S	
AC-4(27)	REDUNDANT/INDEPENDENT FILTERING MECHANISMS	S	
AC-4(28)	LINEAR FILTER PIPELINES	S	
AC-4(29)	FILTER ORCHESTRATION ENGINES	O/S	
AC-4(30)	FILTER MECHANISMS USING MULTIPLE PROCESSES	S	
AC-4(31)	FAILED CONTENT TRANSFER PREVENTION	S	
AC-4(32)	PROCESS REQUIREMENTS FOR INFORMATION TRANSFER	S	
AC-5	Separation of Duties	O	
AC-6	Least Privilege	O	
AC-6(1)	AUTHORIZE ACCESS TO SECURITY FUNCTIONS	O	
AC-6(2)	NON-PRIVILEGED ACCESS FOR NONSECURITY FUNCTIONS	O	
AC-6(3)	NETWORK ACCESS TO PRIVILEGED COMMANDS	O	
AC-6(4)	SEPARATE PROCESSING DOMAINS	O/S	
AC-6(5)	PRIVILEGED ACCOUNTS	O	
AC-6(6)	PRIVILEGED ACCESS BY NON-ORGANIZATIONAL USERS	O	
AC-6(7)	REVIEW OF USER PRIVILEGES	O	
AC-6(8)	PRIVILEGE LEVELS FOR CODE EXECUTION	S	
AC-6(9)	LOG USE OF PRIVILEGED FUNCTIONS	S	
AC-6(10)	PROHIBIT NON-PRIVILEGED USERS FROM EXECUTING PRIVILEGED FUNCTIONS	S	
AC-7	Unsuccessful Logon Attempts	S	
AC-7(1)	AUTOMATIC ACCOUNT LOCK	W: Incorporated into AC-7.	
AC-7(2)	PURGE OR WIPE MOBILE DEVICE	S	
AC-7(3)	BIOMETRIC ATTEMPT LIMITING	O	
AC-7(4)	USE OF ALTERNATE AUTHENTICATION FACTOR	O/S	
AC-8	System Use Notification	O/S	
AC-9	Previous Logon Notification	S	
AC-9(1)	UNSUCCESSFUL LOGONS	S	

CONTROL NUMBER	CONTROL NAME CONTROL ENHANCEMENT NAME	IMPLEMENTED BY	ASSURANCE
AC-9(2)	SUCCESSFUL AND UNSUCCESSFUL LOGONS	S	
AC-9(3)	NOTIFICATION OF ACCOUNT CHANGES	S	
AC-9(4)	ADDITIONAL LOGON INFORMATION	S	
AC-10	Concurrent Session Control	S	
AC-11	Device Lock	S	
AC-11(1)	PATTERN-HIDING DISPLAYS	S	
AC-12	Session Termination	S	
AC-12(1)	USER-INITIATED LOGOUTS	O/S	
AC-12(2)	TERMINATION MESSAGE	S	
AC-12(3)	TIMEOUT WARNING MESSAGE	S	
AC-13	Supervision and Review-Access Control	W: Incorporated into AC-2 and AU-6.	
AC-14	Permitted Actions without Identification or Authentication	O	
AC-14(1)	NECESSARY USES	W: Incorporated into AC-14.	
AC-15	Automated Marking	W: Incorporated into MP-3.	
AC-16	Security and Privacy Attributes	O	
AC-16(1)	DYNAMIC ATTRIBUTE ASSOCIATION	S	
AC-16(2)	ATTRIBUTE VALUE CHANGES BY AUTHORIZED INDIVIDUALS	S	
AC-16(3)	MAINTENANCE OF ATTRIBUTE ASSOCIATIONS BY SYSTEM	S	
AC-16(4)	ASSOCIATION OF ATTRIBUTES BY AUTHORIZED INDIVIDUALS	S	
AC-16(5)	ATTRIBUTE DISPLAYS ON OBJECTS TO BE OUTPUT	S	
AC-16(6)	MAINTENANCE OF ATTRIBUTE ASSOCIATION	O	
AC-16(7)	CONSISTENT ATTRIBUTE INTERPRETATION	O	
AC-16(8)	ASSOCIATION TECHNIQUES AND TECHNOLOGIES	S	
AC-16(9)	ATTRIBUTE REASSIGNMENT — REGRADING MECHANISMS	O	
AC-16(10)	ATTRIBUTE CONFIGURATION BY AUTHORIZED INDIVIDUALS	O	
AC-17	Remote Access	O	
AC-17(1)	MONITORING AND CONTROL	O/S	
AC-17(2)	PROTECTION OF CONFIDENTIALITY AND INTEGRITY USING ENCRYPTION	S	
AC-17(3)	MANAGED ACCESS CONTROL POINTS	S	
AC-17(4)	PRIVILEGED COMMANDS AND ACCESS	O	
AC-17(5)	MONITORING FOR UNAUTHORIZED CONNECTIONS	W: Incorporated into SI-4.	
AC-17(6)	PROTECTION OF MECHANISM INFORMATION	O	
AC-17(7)	ADDITIONAL PROTECTION FOR SECURITY FUNCTION ACCESS	W: Incorporated into AC-3(10).	
AC-17(8)	DISABLE NONSECURE NETWORK PROTOCOLS	W: Incorporated into CM-7.	
AC-17(9)	DISCONNECT OR DISABLE ACCESS	O	
AC-17(10)	AUTHENTICATE REMOTE COMMANDS	S	
AC-18	Wireless Access	O	
AC-18(1)	AUTHENTICATION AND ENCRYPTION	S	
AC-18(2)	MONITORING UNAUTHORIZED CONNECTIONS	W: Incorporated into SI-4.	
AC-18(3)	DISABLE WIRELESS NETWORKING	O/S	
AC-18(4)	RESTRICT CONFIGURATIONS BY USERS	O	
AC-18(5)	ANTENNAS AND TRANSMISSION POWER LEVELS	O	

CONTROL NUMBER	CONTROL NAME CONTROL ENHANCEMENT NAME	IMPLEMENTED BY	ASSURANCE
AC-19	Access Control for Mobile Devices	O	
AC-19(1)	USE OF WRITABLE AND PORTABLE STORAGE DEVICES	W: Incorporated into MP-7.	
AC-19(2)	USE OF PERSONALLY OWNED PORTABLE STORAGE DEVICES	W: Incorporated into MP-7.	
AC-19(3)	USE OF PORTABLE STORAGE DEVICES WITH NO IDENTIFIABLE OWNER	W: Incorporated into MP-7.	
AC-19(4)	RESTRICTIONS FOR CLASSIFIED INFORMATION	O	
AC-19(5)	FULL DEVICE OR CONTAINER-BASED ENCRYPTION	O	
AC-20	Use of External Systems	O	
AC-20(1)	LIMITS ON AUTHORIZED USE	O	
AC-20(2)	PORTABLE STORAGE DEVICES — RESTRICTED USE	O	
AC-20(3)	NON-ORGANIZATIONALLY OWNED SYSTEMS — RESTRICTED USE	O	
AC-20(4)	NETWORK ACCESSIBLE STORAGE DEVICES — PROHIBITED USE	O	
AC-20(5)	PORTABLE STORAGE DEVICES — PROHIBITED USE	O	
AC-21	Information Sharing	O	
AC-21(1)	AUTOMATED DECISION SUPPORT	S	
AC-21(2)	INFORMATION SEARCH AND RETRIEVAL	S	
AC-22	Publicly Accessible Content	O	
AC-23	Data Mining Protection	O	
AC-24	Access Control Decisions	O	
AC-24(1)	TRANSMIT ACCESS AUTHORIZATION INFORMATION	S	
AC-24(2)	NO USER OR PROCESS IDENTITY	S	
AC-25	Reference Monitor	S	✓

TABLE C-2: AWARENESS AND TRAINING FAMILY

CONTROL NUMBER	CONTROL NAME CONTROL ENHANCEMENT NAME	IMPLEMENTED BY	ASSURANCE
AT-1	Policy and Procedures	O	✓
AT-2	Literacy Training and Awareness	O	✓
AT-2(1)	PRACTICAL EXERCISES	O	✓
AT-2(2)	INSIDER THREAT	O	✓
AT-2(3)	SOCIAL ENGINEERING AND MINING	O	✓
AT-2(4)	SUSPICIOUS COMMUNICATIONS AND ANOMALOUS SYSTEM BEHAVIOR	O	✓
AT-2(5)	ADVANCED PERSISTENT THREAT	O	✓
AT-2(6)	CYBER THREAT ENVIRONMENT	O	✓
AT-3	Role-Based Training	O	✓
AT-3(1)	ENVIRONMENTAL CONTROLS	O	✓
AT-3(2)	PHYSICAL SECURITY CONTROLS	O	✓
AT-3(3)	PRACTICAL EXERCISES	O	✓
AT-3(4)	SUSPICIOUS COMMUNICATIONS AND ANOMALOUS SYSTEM BEHAVIOR	W: Incorporated into AT-2(4).	
AT-3(5)	PROCESSING PERSONALLY IDENTIFIABLE INFORMATION	O	✓
AT-4	Training Records	O	✓
AT-5	Contacts with Security Groups and Associations	W: Incorporated into PM-15.	
AT-6	Training Feedback	O	✓

TABLE C-3: AUDIT AND ACCOUNTABILITY FAMILY

CONTROL NUMBER	CONTROL NAME CONTROL ENHANCEMENT NAME	IMPLEMENTED BY	ASSURANCE
AU-1	Policy and Procedures	O	✓
AU-2	Event Logging	O	
AU-2(1)	COMPILATION OF AUDIT RECORDS FROM MULTIPLE SOURCES	W: Incorporated into AU-12.	
AU-2(2)	SELECTION OF AUDIT EVENTS BY COMPONENT	W: Incorporated into AU-12.	
AU-2(3)	REVIEWS AND UPDATES	W: Incorporated into AU-2.	
AU-2(4)	PRIVILEGED FUNCTIONS	W: Incorporated into AC-6(9).	
AU-3	Content of Audit Records	S	
AU-3(1)	ADDITIONAL AUDIT INFORMATION	S	
AU-3(2)	CENTRALIZED MANAGEMENT OF PLANNED AUDIT RECORD CONTENT	W: Incorporated into PL-9.	
AU-3(3)	LIMIT PERSONALLY IDENTIFIABLE INFORMATION ELEMENTS	O	
AU-4	Audit Log Storage Capacity	O/S	
AU-4(1)	TRANSFER TO ALTERNATE STORAGE	O/S	
AU-5	Response to Audit Logging Process Failures	S	
AU-5(1)	STORAGE CAPACITY WARNING	S	
AU-5(2)	REAL-TIME ALERTS	S	
AU-5(3)	CONFIGURABLE TRAFFIC VOLUME THRESHOLDS	S	
AU-5(4)	SHUTDOWN ON FAILURE	S	
AU-5(5)	ALTERNATE AUDIT LOGGING CAPABILITY	O	
AU-6	Audit Record Review, Analysis, and Reporting	O	✓
AU-6(1)	AUTOMATED PROCESS INTEGRATION	O	✓
AU-6(2)	AUTOMATED SECURITY ALERTS	W: Incorporated into SI-4.	
AU-6(3)	CORRELATE AUDIT RECORD REPOSITORIES	O	✓
AU-6(4)	CENTRAL REVIEW AND ANALYSIS	S	✓
AU-6(5)	INTEGRATED ANALYSIS OF AUDIT RECORDS	O	✓
AU-6(6)	CORRELATION WITH PHYSICAL MONITORING	O	✓
AU-6(7)	PERMITTED ACTIONS	O	✓
AU-6(8)	FULL TEXT ANALYSIS OF PRIVILEGED COMMANDS	O	✓
AU-6(9)	CORRELATION WITH INFORMATION FROM NONTECHNICAL SOURCES	O	✓
AU-6(10)	AUDIT LEVEL ADJUSTMENT	W: Incorporated into AU-6.	
AU-7	Audit Record Reduction and Report Generation	S	✓
AU-7(1)	AUTOMATIC PROCESSING	S	✓
AU-7(2)	AUTOMATIC SORT AND SEARCH	W: Incorporated into AU-7(1).	
AU-8	Time Stamps	S	
AU-8(1)	SYNCHRONIZATION WITH AUTHORITATIVE TIME SOURCE	W: Moved to SC-45(1).	
AU-8(2)	SECONDARY AUTHORITATIVE TIME SOURCE	W: Moved to SC-45(2).	
AU-9	Protection of Audit Information	S	
AU-9(1)	HARDWARE WRITE-ONCE MEDIA	S	
AU-9(2)	STORE ON SEPARATE PHYSICAL SYSTEMS OR COMPONENTS	S	
AU-9(3)	CRYPTOGRAPHIC PROTECTION	S	
AU-9(4)	ACCESS BY SUBSET OF PRIVILEGED USERS	O	
AU-9(5)	DUAL AUTHORIZATION	O/S	
AU-9(6)	READ-ONLY ACCESS	O/S	

CONTROL NUMBER	CONTROL NAME CONTROL ENHANCEMENT NAME	IMPLEMENTED BY	ASSURANCE
AU-9(7)	STORE ON COMPONENT WITH DIFFERENT OPERATING SYSTEM	O	
AU-10	Non-repudiation	S	✓
AU-10(1)	ASSOCIATION OF IDENTITIES	S	✓
AU-10(2)	VALIDATE BINDING OF INFORMATION PRODUCER IDENTITY	S	✓
AU-10(3)	CHAIN OF CUSTODY	O/S	✓
AU-10(4)	VALIDATE BINDING OF INFORMATION REVIEWER IDENTITY	S	✓
AU-10(5)	DIGITAL SIGNATURES	W: Incorporated into SI-7.	
AU-11	Audit Record Retention	O	
AU-11(1)	LONG-TERM RETRIEVAL CAPABILITY	O	✓
AU-12	Audit Record Generation	S	
AU-12(1)	SYSTEM-WIDE AND TIME-CORRELATED AUDIT TRAIL	S	
AU-12(2)	STANDARDIZED FORMATS	S	
AU-12(3)	CHANGES BY AUTHORIZED INDIVIDUALS	S	
AU-12(4)	QUERY PARAMETER AUDITS OF PERSONALLY IDENTIFIABLE INFORMATION	S	
AU-13	Monitoring for Information Disclosure	O	✓
AU-13(1)	USE OF AUTOMATED TOOLS	O/S	✓
AU-13(2)	REVIEW OF MONITORED SITES	O	✓
AU-13(3)	UNAUTHORIZED REPLICATION OF INFORMATION	O/S	✓
AU-14	Session Audit	S	✓
AU-14(1)	SYSTEM START-UP	S	✓
AU-14(2)	CAPTURE AND RECORD CONTENT	W: Incorporated into AU-14.	
AU-14(3)	REMOTE VIEWING AND LISTENING	S	✓
AU-15	Alternate Audit Logging Capability	W: Moved to AU-5(5).	
AU-16	Cross-Organizational Audit Logging	O	
AU-16(1)	IDENTITY PRESERVATION	O	
AU-16(2)	SHARING OF AUDIT INFORMATION	O	
AU-16(3)	DISASSOCIABILITY	O	

TABLE C-4: ASSESSMENT, AUTHORIZATION, AND MONITORING FAMILY

CONTROL NUMBER	CONTROL NAME CONTROL ENHANCEMENT NAME	IMPLEMENTED BY	ASSURANCE
CA-1	Policy and Procedures	O	✓
CA-2	Control Assessments	O	✓
CA-2(1)	INDEPENDENT ASSESSORS	O	✓
CA-2(2)	SPECIALIZED ASSESSMENTS	O	✓
CA-2(3)	LEVERAGING RESULTS FROM EXTERNAL ORGANIZATIONS	O	✓
CA-3	Information Exchange	O	✓
CA-3(1)	UNCLASSIFIED NATIONAL SECURITY SYSTEM CONNECTIONS	W: Moved to SC-7(25).	
CA-3(2)	CLASSIFIED NATIONAL SECURITY SYSTEM CONNECTIONS	W: Moved to SC-7(26).	
CA-3(3)	UNCLASSIFIED NON-NATIONAL SECURITY SYSTEM CONNECTIONS	W: Moved to SC-7(27).	
CA-3(4)	CONNECTIONS TO PUBLIC NETWORKS	W: Moved to SC-7(28).	
CA-3(5)	RESTRICTIONS ON EXTERNAL SYSTEM CONNECTIONS	W: Incorporated into SC-7(5).	
CA-3(6)	TRANSFER AUTHORIZATIONS	O/S	✓
CA-3(7)	TRANSITIVE INFORMATION EXCHANGES	O/S	✓
CA-4	Security Certification	W: Incorporated into CA-2.	
CA-5	Plan of Action and Milestones	O	✓
CA-5(1)	AUTOMATION SUPPORT FOR ACCURACY AND CURRENCY	O	✓
CA-6	Authorization	O	✓
CA-6(1)	JOINT AUTHORIZATION — INTRA-ORGANIZATION	O	✓
CA-6(2)	JOINT AUTHORIZATION — INTER-ORGANIZATION	O	✓
CA-7	Continuous Monitoring	O	✓
CA-7(1)	INDEPENDENT ASSESSMENT	O	✓
CA-7(2)	TYPES OF ASSESSMENTS	W: Incorporated into CA-2.	
CA-7(3)	TREND ANALYSES	O	✓
CA-7(4)	RISK MONITORING	O/S	✓
CA-7(5)	CONSISTENCY ANALYSIS	O	✓
CA-7(6)	AUTOMATION SUPPORT FOR MONITORING	O/S	✓
CA-8	Penetration Testing	O	✓
CA-8(1)	INDEPENDENT PENETRATION TESTING AGENT OR TEAM	O	✓
CA-8(2)	RED TEAM EXERCISES	O	✓
CA-8(3)	FACILITY PENETRATION TESTING	O	✓
CA-9	Internal System Connections	O	✓
CA-9(1)	COMPLIANCE CHECKS	O/S	✓